Enhancement One Narrative

Reece Martin

1. Artifact Description

   The artifact I selected is the Travlr Getaways full-stack web application that I originally created in CS 465. The project includes a customer-facing travel website, an Angular administrative application, a Node.js and Express backend, REST API routes, user authentication, and a MongoDB database. The application allows travel information to be displayed to customers while an authenticated administrator can add and edit trip information. I used this project for my ePortfolio because it represents one of the more complete applications I created during my Computer Science program and it combines several different areas of software development into one project.

2. Justification

   I chose Travlr Getaways because it demonstrates my ability to work in both the frontend and backend of an application. Some of the main components that demonstrate my software development skills are the Express routes and controllers, MongoDB integration, and the authentication system. The original project already used JWTs to determine whether a user was logged in, but the authentication code was located directly in the API routing file. The application also did not distinguish between different types of users.

   For my enhancement, I improved the organization and security of the application by creating reusable authentication middleware and adding role-based authorization. I moved the JWT authentication logic out of the routing file and into its own middleware file. I also added a role property to the user model with “user” and “admin” roles. The user's role is now included in the JWT when the user logs in. Administrative routes for adding and editing trips now require a valid JWT as well as the “admin” role.

   I also made public registration assign the “user” role instead of taking a role from the registration request. This prevents a new user from requesting admin privileges when creating an account. After completing the changes, I tested both roles. An admin role was able to add and edit trips successfully, while the user role was prevented from modifying trip information.

3. Course Outcomes

   This enhancement addressed outcomes 3, 4, and 5. For outcome 3, I improved the design of the application by separating authentication and authorization from the routing logic. For outcome 4, I used skills and tools from previous coursework, including Express, JWT authentication, and MongoDB to improve an existing application. Outcome 5 was demonstrated through the security improvements. The original application checked whether a user was authenticated. Now the application checks if the user has permission.

Enhancement One Narrative

Reece Martin

4. Reflection

   The biggest thing I learned from this enhancement was the difference between authentication and authorization. Before making these changes, the application mainly answered the question of whether a user was logged in. The enhancement made me consider the separate question of what that user should actually be allowed to do. Adding roles helped me understand why a secure application should not assume that every authenticated user should have the same permissions.

   One challenge was adding the role system without breaking the authentication that was already working. The user model, JWT, middleware, routes, and MongoDB user record all had to work together. I also learned that changing a user's role in MongoDB does not change a JWT that has already been issued. I had to log out and log back in so that a new token containing the updated role would be generated. Testing both an administrator and a regular user helped me understand how the different pieces of the authentication process work together. Overall, this enhancement improved more than just the functionality of the original project. It helped me better understand how application architecture and security decisions are connected.